

HOME & STAY · PRIVACY GOVERNANCE

홈앤스테이 공개 데이터·개인정보 보호 정책

문서 ID POL-EXPOSURE-001

버전 V.01.0

기준일·시행일 2026-09-04

상태 현행

적용 API · HTML · 다운로드 · 사진 · 로그 · 통계

공개 여부가 불명확하면 공개하지 않습니다.

문서 ID: POL-EXPOSURE-001

문서 유형: PO 정책

버전: V.01.0

상태: 현행

기준일: 2026-09-04

시행일: 2026-09-04

상위 정책: POL-DATA-003 데이터 수집·검증·승격·노출·갱신 통합 정책

대체 문서: 없음

적용 범위: 공개·로그인·소유자·중개사·관리자 화면, API, HTML, 다운로드 파일, 사진, 로그, 통계

다음 검토일: 2026-09-11

마지막 검증 기준: `app.py`, `static/js/main.js` 의 2026-09-04 작업본과 대조

1. 목적과 권위

이 문서는 서비스가 보유한 영업상태, 매물, 계정, 연락처, 접속이력, 사진과 통계를 누구에게 어느 범위까지 제공할지 정하는 권위 문서다. 공개 여부가 불명확하면 공개하지 않는다.

이 문서와 코드가 다르면 다음 순서로 처리한다.

- 신규 배포와 데이터 공개 확대를 중단한다.
- 이미 공개 중인 정보가 금지 항목이면 노출 경로와 공유 캐시를 즉시 차단한다.
- 코드, API 스키마, 화면, 다운로드와 로그를 이 정책에 맞춘다.
- 역할별 회귀검사를 통과한 뒤 배포를 재개한다.

법령, 정보주체의 동의 또는 별도 계약이 더 엄격한 보호를 요구하면 그 기준을 우선한다.

2. 핵심 원칙

2.1 최소 공개

- 각 응답은 현재 기능을 제공하는 데 필요한 최소 필드만 포함한다.
- 화면에서 숨기는 것만으로 보호하지 않는다. 서버 조회와 응답 직렬화 단계에서 제거한다.
- 관리자 응답 객체를 공개 응답에 재사용하지 않는다. 역할별 projection을 별도로 둔다.
- 내부 ID, 상태 키, 원본 행, 검토 메모와 오류 상세는 공개 계약이 아니다.
- 사용자가 추측 가능한 URL을 알아도 비공개 객체를 읽을 수 없어야 한다.

2.2 목적·역할 제한

- 로그인은 모든 개인정보의 열람 허가가 아니다.
- 소유자는 본인이 등록하거나 생성한 자료만 본다.
- 중개사는 배정·담당·계약상 필요한 자료만 본다.
- 관리자는 업무상 필요한 범위에서만 열람하며, 관리자 권한을 공개 API로 위임하지 않는다.
- 같은 사용자가 여러 역할을 가져도 요청 시점에 확인된 역할과 객체 관계를 모두 검증한다.

2.3 실패 시 닫힘

- 인증, 역할, 소유권 또는 공개범위를 확인할 수 없으면 응답하지 않는다.
- 비공개 객체의 존재 여부를 불필요하게 확인해 주지 않는다.
- 캐시가 권한 변경을 우회하지 않도록 개인정보·제한공개 응답은 공유 캐시하지 않는다.
- 마스킹 실패, projection 누락 또는 원본 응답 혼입이 의심되면 전체 응답을 중단한다.

3. 역할별 열람 범위

아래 표의 “소유자”는 해당 매물·사진·대화·요청을 만든 본인, “중개사”는 실제 배정 또는 담당 관계가 확인된 승인 중개사를 뜻한다.

정보 영역	공개(비로그인 포함)	로그인 사용자	소유자	배정·담당 중개사	관리자
공개 건물·시설 기본정보	공개 승인 필드만	공개와 동일	공개와 동일	공개와 동일, 업무상 승인 필드 별도	원본·검토 정보 포함 가능
정상영업 기반 숙박 분류·집계	집계 결과만	공개와 동일	공개와 동일	공개와 동일	상태별 내부 집계 열람 가능
휴업·폐업·취소· 말소	개별 상태·날짜·건수 모두 금지	공개와 동일	본인 자료의 처리에 필요한 경우만	배정 업무상 필요한 경우만	검증·운영 목적 열람
공개 매물	공개 projection만	공개 projection + 본인 반응 상태	본인 원본·처리상태	배정된 의뢰의 업무 필드	전체 운영 필드
제한공개 매물	존재·자동 건물값·정확 위치·사진 금지	공개와 동일	본인 원본 전체	배정 관계와 목적 확인 후 최소 범위	운영·분쟁처리 목적 전체
연락처	금지	본인 연락처만	본인 연락처·본인이 제공받기로 한 상태 연락처	배정 의뢰 연락처만	업무상 필요한 계정 연락처
채팅·첨부파일	금지	본인이 참여한 방안	본인이 참여한 방안	본인이 참여하거나 업무상 배정된 방안	신고·분쟁 등 승인된 목적만
사진	공개 승인본만	공개 승인본	본인 비공개 원본·공개설정	배정 자료의 승인 범위	원본·검증 메타 열람 가능
접속이력	금지	본인에게 별도 제공 기능이 있을 때 본인분만	동일	타인의 이력 금지	감사·보안 목적의 최소 이력
내부 상태· 검토정보	금지	금지	본인 요청의 사용자용 상태만	배정 건의 사용자용 상태만	상태 키·run ID· 검토 메모 등 열람
다운로드	공개용으로 승인된 파일만	본인용 내보내기만	본인 자료	배정 업무 자료	권한·목적에 따른 관리자 내보내기

역할표가 허용하더라도 비밀번호 해시, 인증 코드, 세션·재설정 토큰, 비밀번호, DB 접속값과 원본 IP는 누구에게도 일반 화면이나
내보내기로 제공하지 않는다.

4. 휴·폐업과 공개 통계

4.1 개별 영업상태 비공개

- 휴업, 폐업, 취소, 말소와 이에 준하는 비활성 상태를 공개 목록·지도·상세·검색·공유 미리보기에서 표시하지 않는다.
- 폐업일, 상태 변경일, 상태 아이콘·색상·문구도 공개하지 않는다.

- 상호명, 주소, 허가번호 일부와 결합해 비활성 여부를 추론할 수 있는 응답을 만들지 않는다.
- 같은 건물에 정상과 비활성 신고가 함께 있으면 공개 서비스는 정상 신고만 대표한다.
- 비활성 신고만 있는 건물은 원장에 보존할 수 있으나 개별 공개 근거로 사용하지 않는다.

4.2 통계 분자·분모 비공개

- 휴업·폐업 건수, 비활성률, 폐업률과 지역별 순위는 공개하지 않는다.
- 신고율 계산에 비활성 이력을 내부 분모로 사용할 수 있으나, 비활성 분자·분모·상태별 중간값은 공개하지 않는다.
- 공개 통계는 승인된 최종 지표와 그 의미를 이해하는 데 필요한 최소 집계만 제공한다.
- 작은 집단이나 교차 필터로 개별 시설의 상태가 추론될 수 있으면 집계를 합치거나 제공하지 않는다.
- 관리자 통계 응답과 공개 통계 응답은 별도 projection으로 유지한다.

현재 코드 대조에서 공개 폐업 통계와 통건물 매물의 영업상태 표시 경로가 확인되었다. 이는 본 정책 시행과 동시에 정책 불일치·즉시 검토 대상이며, 공개 허용의 선례로 해석하지 않는다.

5. 제한공개 매물

- 제한공개는 “일부 필드만 숨김”이 아니라 기본 비공개다.
- 정확한 건물 ID·건물명·주소·좌표·호실·자동 산출 건물값·체크리스트·사진·연락처를 공개하지 않는다.
- 건물 마스터나 다른 공개 API와 결합해 정확한 대상을 재식별할 수 있는 값도 제공하지 않는다.
- 위치 안내가 필요하다면 정책이 승인한 넓은 지역 단위와 비결정적 표시만 사용한다.
- 공개범위를 축소하면 기존 사진 URL과 다운로드 URL도 즉시 권한을 다시 확인해야 한다.
- 제한공개 객체의 사진은 소유자 또는 명시적으로 허용된 담당자만 읽을 수 있고 공유 캐시는 금지한다.

6. 개인정보와 계정정보

6.1 연락처

- 전화번호와 이메일은 공개 API, 공개 HTML, 검색 색인, 공유 미리보기와 공개 다운로드에 넣지 않는다.
- 로그인한 사용자에게도 본인 또는 실제 거래·배정 관계가 확인된 상대의 필요한 연락처만 제공한다.
- 목록 응답보다 상세 권한 확인 이후의 별도 응답을 우선한다.
- 화면 마스킹만 믿지 않고 서버에서 원문 필드를 제거하거나 목적에 맞게 마스킹한다.
- 로그에는 전화번호·이메일 원문을 기록하지 않고 내부 주체 ID와 결과 코드로 대체한다.

6.2 인증정보

- 비밀번호 원문·해시, 인증번호, 세션 식별자, 비밀번호 재설정 토큰, OAuth 토큰과 서명 URL을 응답·HTML·다운로드·로그에 넣지 않는다.
- 계정 존재 여부를 인증 실패 메시지나 비밀번호 재설정 응답으로 구분할 수 없게 한다.
- 오류 메시지에 요청 본문이나 인증 헤더를 그대로 포함하지 않는다.

6.3 접속이력

- 일반회원 접속이력은 공개하거나 다른 회원·중개사에게 제공하지 않는다.
- 원본 IP는 저장·표시하지 않고, 보안 목적의 비가역 식별값과 필요한 사용자 환경만 최소 저장한다.

- 관리자 열람은 감사·보안·분쟁 대응 목적과 조회 대상·기간을 제한한다.
- 접속이력 다운로드는 기본 금지하며 별도 승인, 사유와 감사기록이 있을 때만 허용한다.

7. 사진과 파일

7.1 사진 공개 전 처리

- 공개 사진은 파일 형식, 크기, 소유·사용권, 공개 설정과 대상 객체의 공개범위를 확인한다.
- EXIF, GPS, 촬영기기, 촬영시각, 작성자, 소프트웨어와 썸네일 메타데이터를 제거한 파생본만 공개한다.
- 원본 파일명과 저장소 객체 키를 공개 이름으로 사용하지 않는다.
- 얼굴, 차량번호, 문서, 출입정보 등 불필요한 개인정보가 보이면 공개하지 않고 재검토한다.
- 공급자 API 키나 서명이 든 원본 URL을 저장·반환하지 않는다.

7.2 다운로드와 첨부파일

- 파일 다운로드 때도 API와 동일한 인증·역할·소유권·객체 공개범위를 매 요청마다 확인한다.
- 링크를 안다는 사실은 권한이 아니다.
- 사용자 파일은 `private`, `no-store`를 기본으로 하고, 공개 승인본만 별도 캐시 정책을 쓸 수 있다.
- 다운로드 파일 내부의 숨은 시트, 문서 속성, 메모, 변경기록, EXIF와 원본 식별자를 제거한다.
- 채팅 첨부파일은 해당 대화 참여자 확인 없이 반환하지 않는다.

8. 채널별 금지 항목

채널	금지 항목
공개 API	비활성 영업상태·날짜·상태별 건수, 내부 분자·분모, 관리자 상태 키·run ID·검토 메모·신뢰도, 연락처, 접속이력, 원본 저장 키, 제한공개 자동 건물값, 비밀·토큰
공개 HTML·JS·메타태그	API 금지 항목, 숨김 DOM·주석·초기 상태 객체 속 개인정보, source map의 운영정보, 공유/검색 메타의 제한공개 정보
로그인·역할별 API	요청자와 무관한 계정·매물·대화·파일, 역할 전체의 일괄 개인정보, 관리자 객체의 무필터 재사용
다운로드 파일	화면에서 숨긴 원본 열, 전화·이메일·접속이력, 숨은 시트·메모·문서 속성, EXIF·GPS, 내부 ID·검토 메모, 비밀 포함 URL
애플리케이션·작업 로그	비밀번호·인증번호·토큰·세션·쿠키·Authorization 헤더·DB URL, 전화·이메일·원본 IP, 요청·응답 전문, 서명 URL, 외부 API 키의 원문·URL 인코딩 형태
오류 응답	SQL·스택 추적·파일 경로·환경변수·공급자 원문 응답, 객체 존재를 드러내는 권한별 차등 상세
캐시·분석	사용자별 응답의 공유 캐시, 개인정보를 분석 이벤트 속성이나 캐시 키에 원문 저장

금지 목록은 예시가 아니라 최소 기준이다. 새로운 필드는 명시적으로 공개 승인되기 전까지 비공개다.

9. 구현·변경 승인 기준

공개 데이터에 영향을 주는 변경은 다음 순서를 지킨다.

1. 데이터 소유자, 목적, 대상 역할, 보존기간과 공개 필요성을 적는다.

2. 공개·로그인·소유자·중개사·관리자별 응답 필드 목록을 확정한다.
3. 서버 조회와 serializer/projection에서 금지 필드를 제거한다.
4. HTML, JS 초기 데이터, 메타태그, 파일과 로그의 우회 노출을 확인한다.
5. 캐시 축소·권한 변경·URL 재사용 시나리오를 확인한다.
6. 아래 회귀검사를 통과하고 검토 증거를 남긴다.

개인정보나 제한공개 범위를 넓히는 변경은 편의 기능으로 처리하지 않고 정책 검토와 명시적 승인을 거친다.

10. 필수 회귀검사

10.1 역할·객체 권한

- [] 비로그인 요청은 공개 허용 필드만 받는다.
- [] 일반 로그인만으로 타인의 연락처·요청·사진·대화를 읽을 수 없다.
- [] 소유자는 본인 객체만 읽고 수정한다.
- [] 중개사는 실제 배정·담당 관계가 없는 객체를 읽지 못한다.
- [] 관리자 route는 관리자 인증 없이 접근할 수 없다.
- [] 존재하는 비공개 ID와 존재하지 않는 ID가 불필요하게 구분되지 않는다.

10.2 휴·폐업·통계

- [] 공개 API와 HTML에 휴업·폐업·취소·말소 상태와 날짜가 없다.
- [] 공개 화면에 폐업 아이콘·색상·문구·순위가 없다.
- [] 공개 통계에 비활성 상태별 건수, 내부 분자·분모와 폐업률이 없다.
- [] 정상+비활성 중복은 정상 우선이고, 비활성-only는 개별 공개되지 않는다.
- [] 관리자 통계 필드가 공개 projection에 합쳐지지 않는다.

10.3 제한공개·연락처·접속이력

- [] 제한공개 매물은 건물 ID·정확 주소·좌표·자동 건물값·사진을 노출하지 않는다.
- [] 공개범위를 축소한 직후 과거 사진 URL·다운로드 URL이 차단된다.
- [] 공개 응답·HTML·메타태그·내보내기에 전화번호와 이메일이 없다.
- [] 로그인 이력은 관리자 권한과 목적이 없으면 조회되지 않는다.
- [] 원본 IP, 세션과 인증값이 응답·로그에 없다.

10.4 사진·파일·로그

- [] 공개 사진 파생본에서 EXIF·GPS·원본 파일명·저장 키가 제거된다.
- [] 파일 프록시는 매 요청마다 참여자·소유권·공개범위를 확인한다.
- [] 사용자·역할별 파일 응답은 공유 캐시되지 않는다.
- [] CSV/XLSX/DOCX/PDF의 숨은 데이터와 문서 속성을 검사한다.
- [] 성공·실패 로그 모두에 연락처, 토큰, 인증 헤더, 서명 URL과 외부 API 키가 없다.
- [] URL 인코딩된 비밀번호도 마스킹된다.

10.5 검사 방식

- API 스키마 고정 테스트와 금지 필드 재귀 탐색을 함께 사용한다.

- 서로 다른 두 사용자와 두 역할로 객체 ID를 교차 요청한다.
- 공개범위를 공개→제한, 제한→공개로 바꾼 뒤 캐시와 기존 URL을 재검사한다.
- HTML 소스, DOM, 네트워크 응답, 메타태그와 다운로드 파일 내부를 모두 검사한다.
- 운영 배포 전 표본 검사와 배포 후 공개 URL 검사를 수행한다.

11. 즉시 검토·차단 조건

다음 중 하나라도 발생하면 정기 검토일을 기다리지 않는다.

- 공개 API, HTML, 검색결과 또는 공유 미리보기에서 휴·폐업 정보가 발견됨
- 전화번호, 이메일, 접속이력, 인증값 또는 관리자 필드가 권한 밖에서 발견됨
- 제한공개 매물의 정확 위치·건물값·사진이 추론 또는 직접 조회됨
- 사진에서 EXIF·GPS 또는 불필요한 개인정보가 확인됨
- 공개 통계에 상태별 건수나 내부 분자·분모가 추가됨
- 새 API·다운로드·로그·분석 이벤트가 개인정보 필드를 다룸
- 관리자 serializer를 공개 route가 재사용함
- 권한 변경 후 기존 URL이나 공유 캐시로 파일을 계속 읽을 수 있음
- 외부 공급자 응답 형식, 법령, 동의문, 이용 목적 또는 보존 기준이 바뀜
- 개인정보·공개범위 관련 장애, 신고 또는 회귀검사 실패가 발생함

즉시 조치:

1. 영향 route·화면·다운로드·캐시를 차단한다.
2. 로그에 개인정보를 더 남기지 말고 증거는 최소 범위로 보존한다.
3. 노출 필드, 대상, 기간, 캐시·검색 색인 전파 범위를 확인한다.
4. 코드와 데이터를 분리해 복구하고 역할별 검사를 다시 수행한다.
5. 필요 시 책임자 검토와 법정 통지 절차를 별도로 판단한다.

12. 책임과 검토 기록

책임	수행 내용
기능 개발자	최소 조회·projection·권한검사·캐시 정책 구현
검토자	역할표, 금지 필드, 우회 경로와 회귀검사 증거 확인
운영 관리자	관리자 접근 최소화, 다운로드·로그·사고 대응 통제
데이터 책임자	통계 산식과 공개 집계가 개별 상태를 드러내지 않는지 승인
문서 관리자	본 정책과 중앙 문서대장·배포본의 버전 일치 유지

검토 기록에는 비밀값이나 개인정보 표본을 복사하지 않는다. 필드명, 판정, 테스트 역할, 상태 코드와 마스킹된 증거만 남긴다.

13. 완료 확인표

- [x] 공개/로그인/소유자/중개사/관리자별 열람 범위 정의
- [x] 휴·폐업 개별정보와 상태별 통계 비공개 정의

- [x] 내부 통계 분자·분모 비공개 정의
- [x] 제한공개 매물과 자동 건물값 보호 정의
- [x] 연락처·접속이력·인증정보 보호 정의
- [x] 사진 EXIF·GPS 제거와 파일 권한 정의
- [x] API·HTML·다운로드·로그별 금지 항목 정의
- [x] 변경 시 회귀검사와 즉시 검토 조건 정의
- [x] 중앙 문서대장 등록
- [x] PDF·DOCX 배포본 제공